Arjun Tech AI Pvt. Ltd.

IT Incident Management and Security Incident Response Policy

Document ID: ATAI-SEC-POL-005

Document Title	IT Incident Management and Security Incident Response Policy
Document ID	ATAI-SEC-POL-005
Company	Arjun Tech AI Pvt. Ltd., Bahadurpally, Hyderabad, Telangana, India
Version	1.0
Publication Date	7 November 2026
Review Date	7 November 2027
Classification	Internal Use Only
Document Owner	Information Security Lead (IT Support department)
Approval Authority	Head of IT and Security
Applies To	All employees, interns and contract staff of Arjun Tech AI Pvt. Ltd.; IT Support Engineers, IT Administrators, IT Support Manager, Information Security Lead, Department Managers and HR
Related Documents	ATAI-IT-POL-001 Employee IT Support Policy; ATAI-SEC-POL-002 Password and Access Management Policy; ATAI-IT-SOP-003 Laptop and IT Asset Replacement Procedure; ATAI-HR-IT-SOP-004 Employee Onboarding and IT Access Provisioning SOP

Fictional-company notice: Arjun Tech AI Pvt. Ltd. is a fictional company created for a software portfolio project. This document describes fictional internal rules based on common enterprise practice. It is not a legal or regulatory requirement and must not be relied on as legal advice. All identifiers, ticket numbers, asset IDs and targets are fictional examples.

Revision History

Version	Date	Author (Role)	Change Description
1.0	7 November 2026	Information Security Lead	Initial release for the Arjun Tech AI knowledge base.

1. Purpose and Scope

1.1 Purpose

This policy defines how IT incidents and security incidents at Arjun Tech AI Pvt. Ltd. (the Company) are reported, classified, investigated, escalated, resolved and reviewed. Its aims are to restore normal service quickly, limit damage from security events, protect Company and customer data, keep a reliable record of what happened, and learn from each serious incident.

1.2 Scope

This policy applies to all Company IT services, devices, accounts, applications, networks and data at the Bahadurpally, Hyderabad office and for remote work, and to every person who uses them. It covers all incident categories listed in section 5, including security incidents. It focuses on defensive response and reporting. It does not describe how to attack systems or bypass controls.

1.3 Definitions

Term	Meaning
Incident	An unplanned interruption to an IT service, or a reduction in its quality, or a failure of a component that has not yet affected service.
Security incident	A confirmed or suspected event that threatens the confidentiality, integrity or availability of Company information, accounts or systems, for example phishing, malware, unauthorised access or data exposure.
Security event	An observation that may or may not be an incident (for example an unusual alert). Events are reported and assessed.
Service request	A request for something new or standard (see section 3).
Priority or severity	The ranking of an incident: Critical / P1, High / P2, Medium / P3, Low / P4. The two words mean the same thing in the Company and the same P1 to P4 scale is used for tickets (ATAI-IT-POL-001).
Impact	How many people, services or how much data are affected.
Urgency	How quickly the incident must be fixed.
Containment	Actions that stop an incident from spreading or causing more harm.
Root cause	The underlying reason why an incident happened.
Restricted data	The Company's most sensitive information: employee personal records, payroll data, credentials and secrets, customer-derived datasets and core source code. Other classes are Confidential, Internal and Public.
ServiceDesk Portal	The ATAI ServiceDesk Portal, the Company ticketing tool.
Security Incident Record (SIR)	A linked record in the ServiceDesk Portal for each security incident, with a number such as ATAI-SIR-000007 (fictional).
Business Hours	9:00 AM to 6:00 PM IST, Monday to Friday, excluding Company holidays.
Escalation Level	Level 1 IT Support Engineer, Level 2 IT Administrator, Level 3 IT Support Manager (and Information Security Lead for security incidents), Level 4 Head of IT and Security.

1.4 Fictional Content Notice

Arjun Tech AI Pvt. Ltd. is a fictional company created for a software portfolio project. The severity rules, targets and retention periods in this policy are fictional internal rules based on common enterprise practice. They are not legal or regulatory requirements. This document does not state what any law requires. Where an external notification could be required, the Company's designated legal advisor must be consulted (section 14).

2. Definition of an IT Incident

An IT incident is any event that is not part of the normal operation of an IT service and that causes, or may cause, an interruption or reduced quality of the service. Examples:

- A laptop that will not start.
- The VPN being unavailable for many users.
- An internal application that is slow or returns errors for a team.
- A user account that is locked or that cannot sign in because of a system fault.
- An internal shared drive that cannot be reached.
- A phishing email that has been clicked, or a lost company laptop (both are security incidents and also IT incidents).

An incident is not the same as a problem. A problem is the underlying cause of one or more incidents. Where several incidents have the same cause, the IT Support Manager opens a problem record and the Information Security Lead or IT Administrator investigates the root cause.

3. Difference Between an IT Service Request and an Incident

Aspect	Incident	Service request
Nature	Something is broken, degraded or at risk	Something new or standard is needed
Examples	Laptop will not start; VPN fails; account compromised	New software; access to a repository; a new mouse; onboarding
ServiceDesk Portal ticket type	Incident	Service Request
Priority	Set by impact and urgency, P1 to P4	Normally P4, unless the Department Manager gives a business reason
Approvals	Normally none	Often needed (Department Manager and others)
Target	Resolution targets in section 6	Fulfilment targets in ATAI-IT-POL-001, ATAI-SEC-POL-002 and ATAI-HR-IT-SOP-004
Process	This policy	ATAI-IT-POL-001 and the relevant SOP

Decision rules:

- If something that worked before has stopped working or is at risk, it is an incident.
- If the employee is asking for something they never had, it is a service request.
- A request to replace a faulty device is first an incident (Hardware) and becomes a replacement under ATAI-IT-SOP-003 if repair is not possible.
- If the IT Support Engineer is unsure, the ticket is treated as an incident until clarified.
- Any request that involves a possible security risk (for example "please reset my password, I think someone knows it") is an incident in the Security category.

4. Incident Management Responsibilities

Role	Responsibilities
Employee	Report incidents and security events immediately, give accurate information, follow instructions, preserve evidence, do not attempt their own investigation, do not delete suspicious messages or files.
IT Support Engineer (Level 1)	Receive reports, register tickets, perform initial assessment and triage, fix simple incidents, update tickets and communicate with employees, escalate according to section 11 and hand all Security tickets to the Information Security Lead.
IT Administrator (Level 2)	Investigate and resolve incidents that need administrator rights, perform containment actions (lock accounts, isolate devices, block senders) when authorised, restore services, preserve logs. Serves as on-call responder outside Business Hours for P1 incidents.
Incident Manager (IT Support Manager, or a delegate on duty)	Coordinates P1 and P2 incidents, assigns resources, tracks targets, manages communication and escalation, and chairs the post-incident review.
Information Security Lead	Leads all security incidents, decides on containment and evidence handling, directs investigations, decides if an incident is a P1, informs the Head of IT and Security, and owns this policy.
Head of IT and Security (Level 4)	Final authority for P1 incidents, informs Company leadership, approves external communication, approves major recovery decisions and approves this policy.
Department Manager	Informs the team, helps provide business impact information, makes staff available, confirms business priorities during recovery.
HR Manager	Involved when an incident may involve employee conduct or negligence, and supports employee-related communication and actions.
Finance Manager	Is informed of lost assets and of incidents with potential financial impact.
Company leadership	Informed of P1 incidents by the Head of IT and Security and decides on customer or external communication.

5. Incident Categories

All incident tickets must use one of seven categories. The same categories are used in ATAI-IT-POL-001 (that policy also uses a Service Request category for non-incidents). Email and collaboration faults are logged under Software for a single user, and under Application Availability for a service-wide fault.

Category	Description	Typical examples	Default resolver
Hardware	Failure or damage of company devices and peripherals	Laptop will not start; monitor failure; docking station fault	IT Support Engineer; replacement under ATAI-IT-SOP-003
Software	Faults in operating systems, applications or the email and collaboration client for one user or a few users	Application crash; update failure; email client error	IT Support Engineer or IT Administrator
Network	Faults in Wi-Fi, wired network, VPN or internet access	Wi-Fi drops; VPN authentication failure; slow network	IT Administrator
Account and Authentication	Problems with signing in, passwords, MFA or locked accounts	Locked account; MFA prompt not arriving; sign-in error	IT Support Engineer under ATAI-SEC-POL-002
Application Availability	A Company application or service is unavailable or seriously slow for many users	Email down; code repository platform not reachable; AI/ML Workbench down	IT Administrator, with the IT Support Manager coordinating
Security	Suspected or confirmed security event	Phishing; malware; lost device; unauthorised access; suspicious login; data exposure	Information Security Lead
Data Access	Problems with permissions to shared drives, applications and data, or restoring data	Cannot open a department folder; accidental deletion; restore request	IT Administrator (access changes follow ATAI-SEC-POL-002)

If an incident fits more than one category, the category with the greater risk is used. A security element always overrides other categories.

6. Incident Severity Classification

6.1 Severity Levels

Priority	Name	Definition
P1	Critical	A Company-wide or business-critical service is unavailable, or a confirmed or highly likely major security impact exists (for example compromise of a privileged account, ransomware, large-scale data exposure), and no workaround exists.
P2	High	A major service is unavailable or seriously degraded for a team or department; or one employee with a critical business task is blocked with no workaround; or a security incident with limited confirmed impact (for example a compromised standard account, or a lost company laptop).
P3	Medium	A fault affecting one person or a small group with a workaround, or a security event that may be a threat but where no harm is confirmed.
P4	Low	A minor fault, a question or a security report with no sign of impact.

Priority is derived from impact and urgency. The same priority matrix as in ATAI-IT-POL-001, section 6.4 applies. The security rules in section 6.3 set minimum priorities.

6.2 Severity Matrix

All times are fictional internal service targets, not guarantees. P1 times are clock hours. P2, P3 and P4 times run in Business Hours.

Priority	Impact	Urgency	First Response	Resolution	Updates	Escalation and notifications
P1 Critical	High: Company-wide, critical service, or confirmed major security impact	High: work stopped, no workaround	15 minutes	4 hours	Every 30 minutes to the Incident Manager; hourly to Company leadership	Level 2 on-call and Level 3 notified at creation; Level 4 notified after 60 minutes if not resolved or under control (for security P1, within 30 minutes of confirmation)
P2 High	High or medium: department or team affected, or limited confirmed security impact	Medium to high	30 minutes	1 Business Day (8 Business Hours)	Every 2 Business Hours	Level 3 notified at 75 percent of the Resolution Target; Level 4 informed if the target is missed; Information Security Lead notified within 30 minutes for security P2
P3 Medium	Medium or low: small group or one person with workaround, or unconfirmed security event	Medium	4 Business Hours	3 Business Days	Daily	Level 3 informed if the target is missed
P4 Low	Low: one person, minor or reporting-only	Low	1 Business Day	5 Business Days	Every 2 Business Days or on change	None unless target missed

6.3 Minimum Priorities for Security Events

The IT Support Engineer sets the minimum priority below. The Information Security Lead may raise it, and lowers it only with a written reason.

Security event	Minimum priority
Phishing email received and reported, not opened or clicked	P4
Phishing email reported by several employees (campaign)	P3
Phishing link clicked but no credentials or files entered	P3
Credentials entered on a phishing page, or an attachment opened	P2
Suspected malware on one device, no sign of spread	P3
Confirmed malware on one device, or device with access to restricted data	P2
Malware on multiple devices, or ransomware behaviour	P1
Unusual sign-in alert, no sign of access	P3
Confirmed unauthorised access to a standard account	P2
Confirmed unauthorised access to a privileged account or to restricted data	P1
Lost or stolen company laptop	P2
Lost or stolen company laptop with unencrypted restricted data, stored privileged credentials or production access	P1
Data sent to a wrong internal recipient, no restricted data	P4
Confidential or restricted data shared with the wrong internal people	P3
Confidential data sent or shared externally by mistake	P2
Restricted data exposed publicly or externally, or large volume of data	P1

A security P2 reported outside Business Hours activates the on-call IT Administrator and the Information Security Lead. This is the approval for after-hours handling mentioned in ATAI-IT-POL-001, section 7.1.

7. Incident Reporting Procedure

7.1 How to Report

Situation	How to report
Any P1 indicator (Company-wide outage, serious security event), any lost or stolen device, any suspected compromised account	Call the IT Support helpline immediately, then create a ticket in the ServiceDesk Portal. The helpline extension is on the intranet IT Support page.
Other incidents	Create a ServiceDesk Portal ticket (type Incident) as described in ATAI-IT-POL-001, section 5.
Portal not available	Use the IT Support mailbox or the walk-up IT Support desk at the Bahadurpally office. IT Support creates the ticket.
Suspicious email	Use the Company's report-phishing function in the email client, or forward the email as an attachment to the IT Support mailbox, and create a Security ticket.

7.2 Reporting Time Limits

- Report any security event immediately after noticing it.
- Lost or stolen company laptop or phone with Company data: within 1 hour of discovery (fictional internal rule). This is the same time limit used in ATAI-IT-SOP-003.
- Unexpected MFA prompts, or credentials entered on a suspicious page: immediately.
- Other incidents: as soon as noticed, and no later than the end of the same working day.

7.3 Information to Include

Name, employee ID, department; asset ID of any device; description of the problem; error text or screenshots; time it started; who else is affected; what was done; and, for security events, what was clicked, opened or entered. Do not write passwords, MFA codes or secrets in the report.

7.4 No Blame for Prompt Reporting

Employees who report promptly, even if they made a mistake, are treated fairly. Delay in reporting causes more harm than the original mistake. The HR Manager is involved only when there is repeated or deliberate disregard of rules.

8. Incident Registration and Documentation

Every incident has a ticket in the ServiceDesk Portal. Security incidents also have a linked Security Incident Record (SIR). The record must contain:

Field	Content
Ticket number and SIR number	For example ATAI-INC-000845 and ATAI-SIR-000007 (fictional)
Reporter and contact	Name, employee ID, department, contact method
Date and time	Detection time, report time, and the time of each later action
Category and subcategory	From section 5
Priority and the reason for it	Impact, urgency, and any security minimum used
Affected assets, accounts and services	Asset IDs, account names, applications
Affected users and data	Number of users, type of data (class of data)
Description	Facts only, with timeline
Actions taken	Who did what and when, including containment
Evidence references	Logs, screenshots, emails and device details held (section 15)
Owner and escalation history	Names by role, levels and times
Resolution and cause	What was done and what caused the incident
Communication log	Who was informed, when, and how
Closure approval	Who approved closure (IT Support Manager for P1 and P2, Information Security Lead for Security)

Rules: the IT Support Engineer creates the record within 15 minutes of the report for P1, and within the Response Target for others. Notes are factual. Opinions and blame are not recorded. Passwords and secrets are never recorded.

9. Initial Assessment and Triage

9.1 Triage Steps

1) The IT Support Engineer confirms the facts with the reporter: what, when, who is affected, whether work is blocked.
2) The Engineer checks whether this is an incident or a service request (section 3).
3) The Engineer assigns the category (section 5).
4) The Engineer checks whether the issue is already known: open incidents, planned maintenance, or a known problem.
5) The Engineer determines impact and urgency, and assigns the priority using the severity matrix. For a Security category, the minimum priority in section 6.3 is applied.
6) If the category is Security, the Engineer notifies the Information Security Lead immediately and does not make further changes to the account or device unless told to.
7) The Engineer gives the reporter the ticket number, the priority and the next step.
8) The Engineer decides whether to resolve it at Level 1 or escalate (section 11).

9.2 Triage Rules

- Do not wait for full information before setting a priority. Set the priority from what is known and correct it later.
- If the Engineer is unsure between two priorities, choose the higher one until more information is gathered.
- If several employees report the same fault within 30 minutes, the Engineer links the tickets to a master incident and asks the IT Support Manager to consider P1 or P2.
- Where a fault affects a critical service, the IT Support Manager is told at once, even before the priority is final.

10. Investigation and Troubleshooting

10.1 General Approach

1) Check what changed recently: updates, configuration changes, new software or access changes.
2) Reproduce or confirm the symptom, and check whether it affects one user or many.
3) Check the status of services and monitoring alerts.
4) Apply the standard fix from the IT knowledge base where one exists.
5) If it does not work, collect diagnostic information (error text, logs, device health, network checks) and escalate with those findings.
6) Record each step in the ticket, including steps that did not work.

10.2 Restoring Service Before Finding the Cause

For P1 and P2 incidents, restoring service has priority over finding the root cause. The IT Administrator uses a workaround or rollback if one is available, and the root cause is investigated afterwards and recorded in the problem record or the post-incident review.

10.3 Rules for Investigation

- Changes to production systems during a P1 or P2 incident need approval from the Incident Manager and are recorded in the ticket.
- Staff access only the data needed for the investigation. Looking at the contents of employee mailboxes or files needs approval from the Information Security Lead and, where employee conduct is involved, from the HR Manager.

- Troubleshooting must not weaken security controls. Disabling security tools, MFA or logging as a quick fix is not allowed.
- If during investigation a security element appears, the ticket is changed to category Security and the Information Security Lead is notified.

11. Escalation Matrix

11.1 Escalation Levels

Level	Role	Responsibility
Level 1	IT Support Engineer	Triage, first-line resolution, communication
Level 2	IT Administrator	Administrative investigation and containment, restoration of services, on-call for P1
Level 3	IT Support Manager (all incidents) and Information Security Lead (security incidents)	Coordination, resourcing, security leadership, target management
Level 4	Head of IT and Security	P1 oversight, Company leadership communication, major decisions

11.2 Escalation Decision Table

Condition	Escalate to	When	Type
Level 1 cannot resolve with standard steps	Level 2	Within 30 minutes (P1, P2) or 2 Business Hours (P3)	Functional
P1 incident created	Level 2 on-call and Level 3	Immediately	Functional and hierarchical
P1 not resolved or not under control	Level 4	After 60 minutes (non-security)	Hierarchical
Security incident, any priority	Information Security Lead	Immediately	Functional
Security P1 confirmed	Head of IT and Security	Within 30 minutes of confirmation	Hierarchical
Security P2 involving a privileged account or restricted data	Head of IT and Security	Within 2 Business Hours	Hierarchical
P2 reaches 75 percent of Resolution Target without a fix	IT Support Manager	At 75 percent point	Hierarchical
P2 misses Resolution Target	Head of IT and Security informed	When missed	Hierarchical
P3 or P4 misses Resolution Target	IT Support Manager	Next Business Day	Hierarchical
Third party or vendor does not respond	IT Support Manager	1 Business Day (P1, P2); 3 Business Days (P3, P4)	Hierarchical
Employee conduct may be involved	HR Manager, informed by Information Security Lead	Same day	Hierarchical
Personal data or customer data may be involved	Head of IT and Security, then Company leadership and legal advisor	Within 2 hours of confirmation	Hierarchical
Incident causes a Company-wide outage	Company leadership informed by Head of IT and Security	Within 1 hour	Hierarchical
Employee disagrees with priority or handling	IT Support Manager	On request	Hierarchical

12. Security Incident Response Workflow

The workflow has seven stages. The Information Security Lead owns every security incident from the moment it is reported.

12.1 Stage 1: Identification

- A security event is detected by an employee, a monitoring alert, an IT Support Engineer, an external party or a vendor.

- The reporter follows section 7. The IT Support Engineer creates the ticket and the Security Incident Record and notifies the Information Security Lead immediately.
- Output: ticket and SIR with first facts and time of detection.

12.2 Stage 2: Initial Assessment

- The Information Security Lead (or deputy) confirms the facts, decides whether it is a real incident, and sets or confirms the priority using section 6.3.
- Target: within 15 minutes for P1 and within 30 minutes for P2 (fictional). For P3 and P4, within the normal Response Target.
- The Information Security Lead decides who is needed: IT Administrator, Incident Manager, HR Manager, Department Manager.
- Output: priority, incident owner, initial scope.

12.3 Stage 3: Containment

- Goal: stop the spread and limit harm, without destroying evidence.
- Targets (fictional): start of containment within 30 minutes of confirmation for P1, within 2 hours for P2, within 1 Business Day for P3.
- Examples of containment actions, carried out by an IT Administrator when authorised by the Information Security Lead:
- Disable or lock an affected account and sign out its active sessions.
- Revoke MFA registrations, tokens and VPN profiles that may be compromised.
- Isolate an affected device from the network (the device is kept powered on unless the Information Security Lead decides otherwise, so that evidence is not lost).
- Block a sender or a malicious link and remove a phishing email from other mailboxes.
- Remotely lock or wipe a lost device (wipe only after the Information Security Lead confirms).
- Remove public sharing from a file or folder.
- Temporarily limit access to an affected system.
- Every action is recorded with time and name.
- Output: containment confirmed in SIR.

12.4 Stage 4: Investigation

- The Information Security Lead directs the investigation: what happened, which accounts, devices and data were affected, how it started, and whether it is still happening.
- The IT Administrator collects and preserves logs and device information (section 15).
- The team reviews sign-in logs, email logs, mailbox rules, forwarding settings, device alerts and file-sharing activity relevant to the incident.
- Findings are written in the SIR, with the evidence references.
- For P1, initial findings are reported within 4 hours (fictional target) and then at the update frequency in section 6.2.
- Output: scope, cause, affected people and data.

12.5 Stage 5: Recovery

- Remove the cause: for example delete malicious messages, remove malicious software using approved tools, or rebuild the device from the standard image.
- Restore services and data from backups where needed.
- Reset passwords and re-enrol MFA under ATAI-SEC-POL-002 (with full identity verification).
- Re-enable accounts and devices only after the Information Security Lead agrees.
- Monitor affected accounts and systems for repeat activity for at least 7 days (fictional).
- A replacement device for a lost or stolen device is issued under ATAI-IT-SOP-003 after containment.
- Output: services restored and verified; monitoring in place.

12.6 Stage 6: Closure

- The incident is closed when all closure criteria in section 16 are met.
- The Information Security Lead approves closure of every security incident.

12.7 Stage 7: Lessons Learned

- The post-incident review (section 17) identifies the root cause, what worked, what did not, and improvement actions with owners and dates.
- Improvements may include a changed procedure, training, a technical control or an update to this policy.

12.8 Security Incident Workflow Summary

Stage	Owner	Target (fictional)	Required output
1 Identification	IT Support Engineer	Report immediately; SIR created within 15 minutes (P1)	Ticket and SIR
2 Initial assessment	Information Security Lead	15 minutes (P1), 30 minutes (P2)	Priority and plan
3 Containment	IT Administrator under Information Security Lead	Start in 30 minutes (P1), 2 hours (P2), 1 Business Day (P3)	Containment confirmed
4 Investigation	Information Security Lead	Initial findings in 4 hours (P1)	Scope and cause
5 Recovery	IT Administrator	Within the Resolution Target	Service restored, monitoring set
6 Closure	Information Security Lead (and IT Support Manager for P1 and P2)	After criteria are met	Approved closure
7 Lessons learned	Incident Manager with Information Security Lead	P1 within 3 Business Days, P2 within 5 Business Days	Review report and actions

13. Examples of Security Incidents

All details in this section are fictional examples.

13.1 Phishing Email

Example: an employee receives an email that looks like it comes from the HR department asking them to sign in to check a payroll document. The employee notices the link looks unusual.

Employee actions: do not click or open anything; use the report-phishing function or forward the email as an attachment to the IT Support mailbox; create a Security ticket.

Response: if nothing was clicked, P4 (P3 if several employees reported it). The Information Security Lead checks whether others received it, and an IT Administrator removes it from all mailboxes and blocks the sender. If the employee clicked the link: P3. If credentials were entered: P2, and the account is secured (section 14.3 of ATAI-SEC-POL-002).

13.2 Suspected Malware

Example: a laptop shows unexpected pop-ups, runs very slowly and the security tool reports a detection that cannot be cleaned.

Employee actions: disconnect from Wi-Fi or the network cable, keep the device powered on unless IT Support says otherwise, do not try to remove the software, and report by helpline.

Response: P3 for suspected malware on one device, P2 if confirmed or if the device has access to restricted data, P1 if more than one device is affected or if files are being encrypted. The IT Administrator isolates the device, the Information Security Lead investigates, and the device is rebuilt after evidence is collected.

13.3 Lost Company Laptop

Example: an employee leaves a laptop in a taxi.

Employee actions: report by helpline immediately and no later than 1 hour after discovery; raise a Security ticket; change passwords from another trusted device.

Response: P2 minimum, P1 if the device held unencrypted restricted data, stored privileged credentials or had production access. The IT Administrator locks or wipes the device and revokes sessions and tokens within 1 hour of confirmation. The IT Asset Coordinator updates the asset status (ATAI-IT-SOP-003, section 12).

13.4 Unauthorised Account Access

Example: an employee finds that emails were sent from their account that they did not write, and that a forwarding rule exists that they did not create.

Employee actions: stop using the account, report by helpline, raise a Security ticket, do not delete anything.

Response: P2 for a standard account, P1 for a privileged account or if restricted data was reached. The account is locked, sessions are signed out, the forwarding rule is preserved as evidence and then removed, and the account is recovered under ATAI-SEC-POL-002.

13.5 Suspicious Login Activity

Example: monitoring shows repeated failed sign-ins for one employee from a foreign location, followed by a block.

Response: P3 if no access happened. The IT Support Engineer contacts the employee to confirm whether it was them. The Information Security Lead reviews the logs, forces a password reset and re-enrolment of MFA if there is any doubt, and watches the account.

13.6 Accidental Data Exposure

Example: an employee shares a spreadsheet containing employee salary data with a link that allows anyone with the link to open it.

Employee actions: remove the sharing if possible, report immediately, do not delete the file.

Response: P1 if restricted data is accessible to the public or externally in large volume, P2 for confidential data with an external recipient, P3 for an internal wrong audience. The IT Administrator removes the access, reviews access logs to see who opened the file, and the Information Security Lead informs the Head of IT and Security and the HR Manager. The Head of IT and Security decides with the legal advisor whether anyone outside the Company must be informed.

14. Communication and Notification Requirements

14.1 Principles

- Communicate facts, in plain language, without blame or speculation.
- Use official channels (ServiceDesk Portal, Company email and chat, helpline).
- Share information only with people who need to know.
- Only the Head of IT and Security, or a person named by them, communicates outside the Company about an incident. Other staff must not discuss incidents externally or on social media.

14.2 Who Must Be Informed

Priority or event	Who must be informed	By whom	When
P1 (any category)	IT Support Manager; Information Security Lead if security; Head of IT and Security; Company leadership	Incident Manager	Level 3 at once; Level 4 per section 11.2; leadership within 1 hour
P2	Department Manager of affected users; IT Support Manager	IT Support Engineer or Incident Manager	Within 2 Business Hours
Security P2 or higher	Information Security Lead; Head of IT and Security as per section 11.2	IT Support Engineer	Within 30 minutes (Information Security Lead)
Employee conduct may be involved	HR Manager	Information Security Lead	Same day
Lost or stolen asset	IT Asset Coordinator; Finance Manager (write-off)	IT Support Engineer	Same working day
Personal data or customer data may be involved	Company leadership and legal advisor	Head of IT and Security	Within 2 hours of confirmation
Planned maintenance affecting users	All affected employees	IT Administrator or IT Support Manager	At least 2 Business Days before (urgent security patches excepted)

14.3 Messages to Employees During an Outage

During a P1 or P2 outage, the Incident Manager sends a Company-wide message by email or chat that contains: what is affected, what employees should do, the next update time, and the ticket number. Updates follow the frequencies in section 6.2. A final message confirms restoration.

14.4 External Notification

The Company may have duties to notify customers, partners or authorities after some incidents. This policy does not state what any law requires. The Head of IT and Security consults the Company's designated legal advisor and Company leadership, and decides on external notification. Records of the decision are kept in the SIR.

15. Evidence Preservation and Audit Trail

15.1 Evidence Rules

- Keep, do not change. Do not delete emails, messages, files, devices or logs related to an incident.
- Evidence includes: the original suspicious emails, screenshots, logs of sign-ins, email and device events, copies of changed configuration, device details and the affected device itself.
- Phishing emails are kept by forwarding them as attachments (not copied as text), so that the original details remain.
- Affected devices are not wiped, re-imaged or returned to stock until the Information Security Lead releases them (ATAI-IT-SOP-003).
- Evidence is stored in a restricted location available only to the Information Security Lead and named IT Administrators.

15.2 Chain of Custody

For devices and exported logs the IT Administrator records: what was collected, the asset ID or log source, who collected it, when, where it is stored, and who has accessed it. Any handover to another person is recorded with date and time.

15.3 Audit Trail and Retention (Fictional Internal Rules)

- Every action in an incident is recorded in the ticket with date, time and role (not only the person's name).
- Security logs are retained for 12 months. Privileged activity logs are retained for 12 months.
- Incident tickets and SIRs are retained for 3 years.
- Records are protected from change. Corrections are made as new entries with a reason.
- The Information Security Lead reviews a sample of closed P1 and P2 incident records each quarter to check that records are complete.

16. Incident Closure Criteria

An incident can be set to Resolved when service is restored, the employee is told and the resolution notes are written. It can be Closed (ATAI-IT-POL-001 lifecycle) only when all criteria below are met.

Criterion	Applies to
Service is restored and checked with the affected users, or the employee confirmed (or 3 Business Days passed without reply)	All incidents
Resolution notes state what was done and what caused the incident	All incidents
Category, priority and times are correct in the ticket	All incidents
Any linked problem record is opened where the cause is not yet removed	All incidents with repeated cause
IT Support Manager reviewed and approved closure	P1 and P2
Containment and recovery are complete, no unauthorised access remains (accounts, rules, tokens, devices)	Security incidents
Evidence is preserved and stored, and the chain of custody is recorded	Security incidents
Affected employees are informed and have completed required actions (password change, MFA re-enrolment, refresher)	Security incidents
Required notifications are completed and recorded	Security incidents
Information Security Lead approved closure	Security incidents
Post-incident review is scheduled	P1 and P2

17. Post-Incident Review

17.1 When

- P1: review within 3 Business Days after resolution.
- P2: review within 5 Business Days after resolution.
- P3 and P4: no individual review. The IT Support Manager reviews trends monthly and starts a review if a pattern appears.
- A review can also be requested by the Head of IT and Security for any incident.

17.2 Who

The Incident Manager (chair), the Information Security Lead for security incidents, the IT Administrators involved, the IT Support Engineer who handled it, the Department Manager of affected users, and the HR Manager where relevant.

17.3 Content of the Review

1) Timeline of the incident, from the first sign to closure.
2) Impact: users, services, data, duration and cost where known.
3) Root cause and contributing factors.
4) What worked well and what did not, including detection time, escalation and communication.
5) Whether targets were met.
6) Improvement actions, each with an owner and due date.

17.4 Rules

- The review is about processes and systems, not blame.
- The review report is stored with the incident record and sent to the Head of IT and Security within 2 Business Days of the review meeting.
- Improvement actions are recorded as tracked tickets. The IT Support Manager reports overdue actions monthly.
- Where the review shows that this policy needs changing, the Information Security Lead raises an update for approval by the Head of IT and Security.

18. Sample Incident Scenarios and Recommended Actions

All names, IDs and cases below are fictional examples.

Scenario	Category	Priority	Recommended actions
Company email is unavailable for all employees at 10:30 AM	Application Availability	P1	Call helpline; IT Administrator on-call starts investigation; Incident Manager sends Company-wide message; Level 4 notified if not resolved in 60 minutes; update every 30 minutes; post-incident review within 3 Business Days
The VPN fails for all remote employees	Network	P1	Same as above; share a workaround where one exists (for example office access); restore VPN service; review root cause
The AI/ML team cannot reach the model training environment	Application Availability	P2	IT Administrator investigates; Level 3 notified at 75 percent of target; update every 2 Business Hours; Department Manager informed
One employee cannot open a department shared folder	Data Access	P3	IT Support Engineer checks permissions; access changes follow ATAI-SEC-POL-002 and need approval
Laptop ATAI-LAP-00188 will not start	Hardware	P3 (P2 if critical deadline approved by the IT Support Manager)	Troubleshoot; Loaner Device if blocked; replacement under ATAI-IT-SOP-003
Ten employees report the same suspicious "invoice" email	Security	P3	Link tickets; Information Security Lead assesses; remove email from all mailboxes; block sender; check for clicks; raise to P2 if credentials were entered
An employee entered credentials on a fake sign-in page	Security	P2	Lock account, sign out sessions, review logs, reset password and re-enrol MFA after verification; check mailbox rules
A developer's laptop shows ransomware message and files are locked	Security	P1	Isolate device from the network, keep it powered on, notify Information Security Lead and Head of IT and Security within 30 minutes, check other devices, preserve evidence, recover from backup, review within 3 Business Days
A privileged administrator account shows sign-ins from an unknown location	Security	P1	Disable the account, revoke tokens, use the break-glass process if needed with Head of IT and Security approval, review all administrator actions, recover accounts, review within 3 Business Days
Laptop stolen from a car, encrypted, no restricted data stored locally	Security	P2	Report within 1 hour; lock or wipe within 1 hour of confirmation; revoke tokens; reset passwords; replacement after containment (ATAI-IT-SOP-003)
A spreadsheet with salary data is shared publicly	Security	P1	Remove sharing; review access logs; inform Head of IT and Security, HR Manager and legal advisor; decide on notifications
An employee mistakenly sends a non-restricted internal file to the wrong colleague	Security	P4	Ask the recipient to delete it; record the event; no further action unless restricted data was included

19. Frequently Asked Questions

Q: What is the difference between an incident and a service request?

A: An incident is something that is broken, degraded or at risk, such as a laptop that will not start or a VPN failure. A service request is a request for something new or standard, such as new software or access. Incidents are prioritised from P1 to P4. Service requests are normally P4.

Q: How do I report a security incident, and how fast?

A: Report it immediately. Call the IT Support helpline for anything serious (for example a compromised account or a lost laptop), then create a ServiceDesk Portal ticket with category Security. Lost or stolen company devices must be reported within 1 hour of discovery.

Q: I clicked a link in a suspicious email. Will I get into trouble?

A: Report it at once. Prompt reporting is treated fairly, and the Company does not blame employees who report quickly. If you entered your password, say so immediately, because the account must be secured. The priority is P3 if you only clicked and P2 if you entered credentials or opened an attachment.

Q: What priority will my incident have?

A: It is set by impact and urgency using the severity matrix in section 6.2. P1 is a Company-wide or critical impact with no workaround, P2 is a team or department affected or a limited security impact, P3 is one person or small group with a workaround, and P4 is minor. The IT Support Engineer confirms the priority.

Q: What are the response and resolution targets?

A: Fictional internal targets: P1 response 15 minutes, resolution 4 hours; P2 30 minutes and 1 Business Day; P3 4 Business Hours and 3 Business Days; P4 1 Business Day and 5 Business Days. These are targets, not guarantees.

Q: What should I do if I think malware is on my laptop?

A: Disconnect from Wi-Fi or the network cable, but keep the laptop powered on unless IT Support tells you otherwise. Do not try to clean it yourself. Call the helpline and create a Security ticket.

Q: I received a suspicious email but did not click anything. What do I do?

A: Use the report-phishing function in the email client, or forward the email as an attachment to the IT Support mailbox, and create a Security ticket. It is a P4 report. If several colleagues report the same message, it becomes P3 and IT removes it from all mailboxes.

Q: Who leads a security incident?

A: The Information Security Lead owns every security incident from the moment it is reported. IT Support Engineers hand Security tickets to the Information Security Lead immediately. The IT Administrator carries out containment actions when authorised.

Q: When is the Head of IT and Security told?

A: For a security P1, within 30 minutes of confirmation. For a non-security P1, if it is not resolved or under control after 60 minutes. For a security P2 involving a privileged account or restricted data, within 2 Business Hours. For any P2 that misses its Resolution Target, when the target is missed.

Q: Why does IT Support keep my laptop and not wipe it after a security incident?

A: The laptop may be needed as evidence. It is not wiped or returned to stock until the Information Security Lead releases it. You will receive a replacement or a Loaner Device under ATAI-IT-SOP-003 if you need to continue working.

Q: Why can I not delete the suspicious message I reported?

A: The original message is evidence. Keep it until the Information Security Lead says it can be removed, or let IT remove it from your mailbox.

Q: When is an incident closed and what happens afterwards?

A: When service is restored, the cause and resolution are documented and, for security incidents, containment, recovery, evidence handling and notifications are complete, and the right person approved closure. P1 and P2 incidents then have a post-incident review within 3 or 5 Business Days.

Q: Will Company leadership or outside parties be told about a data exposure?

A: The Head of IT and Security informs Company leadership, and with the Company's designated legal advisor decides whether anyone outside the Company must be informed. This policy does not state what any law requires.